

Policy_ID: CIP-AUP-003

Policy_Name: Acceptable Use & Asset Governance Policy

Version: 2.2 Effective_Date: 2025-02-01

Risk_Category: IT Operations Applicable_Regulations: [SOC 2, ISO 27001]

Owner: Chief Technology & Security Officer (CTSO)

Acceptable Use & Asset Governance Policy

1. Scope & Definitions [Risk Score: 1]

This policy applies to all employees, contractors, and third parties using Capstone digital assets, cloud systems, and remote infrastructure.

- **Shadow IT:** Any software/hardware used without IT authorization.
- **Privileged Access:** Admin-level permissions requiring elevated clearance.

2. Asset Ownership [Risk Score: 3]

Capstone retains ownership of all corporate devices, software, and data.

- **Monitoring:** Capstone monitors device activity, email headers, and access logs.
- **Remote Wipe:** Capstone reserves the right to wipe devices remotely if a threat arises.

Non-Compliance Impact: Tampering with monitoring agents is a **Medium Risk** violation.

3. Acceptable Use Guidelines [Risk Score: 3]

Permitted:

- Job-related tasks on corporate systems.
- Limited personal browsing (non-disruptive).

Strictly Prohibited:

- **Shadow IT:** Unapproved automation tools, AI plugins, or remote desktop software.
- **Cryptomining:** Using company hardware for personal mining.
- **Data Exfiltration:** Sending work data to personal email/cloud (Google Drive, Dropbox).

Non-Compliance Impact: Use of Shadow IT is a **Medium to High Risk** depending on the tool. Exfiltrating data to personal cloud is a **High Risk** (Score 4) violation.

4. Network Security [Risk Score: 4]

- **Public Wi-Fi:** Allowed **ONLY** via Capstone VPN.
- **USB Devices:** Connecting untrusted USB hubs or chargers is prohibited.
- **VPN:** Mandatory for accessing internal dashboards or Git repositories.

Non-Compliance Impact: Accessing sensitive systems over public Wi-Fi without VPN is a **High Risk** security violation.

5. BYOD & Physical Security [Risk Score: 3]

- **Unattended Devices:** Devices must never be left unattended in vehicles or public spaces.
- **Loss Reporting:** Theft or loss must be reported within **1 hour**.
- **BYOD:** Personal devices allowed only with explicit Mobile Device Management (MDM) enrollment.

Non-Compliance Impact: Failure to report a lost device within 1 hour is a **Medium Risk** violation affecting incident response timelines.